



PANDUAN

PENANGANAN INSIDEN

SERANGAN

SQL INJECTION



Deputi Bidang Keamanan Siber dan Sandi Pemerintahan dan
Pembangunan Manusia

Badan Siber dan Sandi Negara

VERSI DOKUMEN

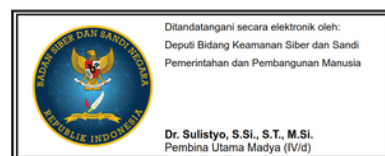
No	Tanggal	Versi Dokumen	Oleh	Keterangan
1	Desember 2018	Versi 0	Deputi III	-
2	Maret 2025	Versi 1	Deputi III	-

KATA PENGANTAR

Puji syukur kehadiran Allah SWT, atas segala limpahan rahmat, nikmat, serta karunia-Nya yang tak ternilai dan tak dapat dihitung sehingga kami dapat menyelesaikan penyusunan “Panduan Penanganan Insiden Serangan SQL Injection”. Panduan ini disusun dalam rangka memberikan acuan bagi pihak yang berkepentingan dalam penanganan insiden serangan SQL Injection. Panduan ini berisikan langkah-langkah yang harus diambil apabila terjadi serangan SQL Injection, yang dimulai dari tahap persiapan sampai dengan tahap pembuatan laporan dari penanganan serangan. Panduan ini tentu saja masih banyak kekurangan dan masih jauh dari kesempurnaan karena keterbatasan ilmu dan referensi kami. Untuk itu, kami selalu berusaha melakukan evaluasi dan perbaikan secara berkala agar bisa mencapai hasil yang lebih baik lagi.

Akhir kata, kami ucapkan terima kasih kepada segala pihak yang telah membantu dalam penyusunan penduan ini.

Depok, Maret 2025



PENDAHULUAN

SQL Injection (SQLi) adalah serangan siber yang memanfaatkan celah keamanan pada aplikasi berbasis database. Serangan ini terjadi ketika penyerang menyisipkan perintah SQL berbahaya melalui input pengguna seperti formulir login, kolom pencarian, atau parameter dalam URL. Jika input tersebut tidak divalidasi dengan baik, perintah yang dimasukkan dapat dieksekusi oleh database, memungkinkan penyerang untuk mencuri, mengubah, atau menghapus data sensitif. SQL Injection juga dapat digunakan untuk mendapatkan akses tidak sah, mengendalikan server database, hingga merusak sistem secara keseluruhan.

TUJUAN

Secara umum, tujuan panduan ini dimaksudkan untuk membantu organisasi memahami tentang penanganan serangan SQL Injection. Sedangkan secara khusus adalah sebagai berikut

01.

Memastikan adanya sumber daya yang memadai untuk menangani serangan yang terjadi;

02.

Melakukan pengumpulan informasi yang akurat;

03.

Meminimalisir dampak dari serangan yang terjadi;

04.

Mencegah adanya serangan lanjutan dan mencegah kerusakan agar tidak lebih meluas.

RUANG LINGKUP

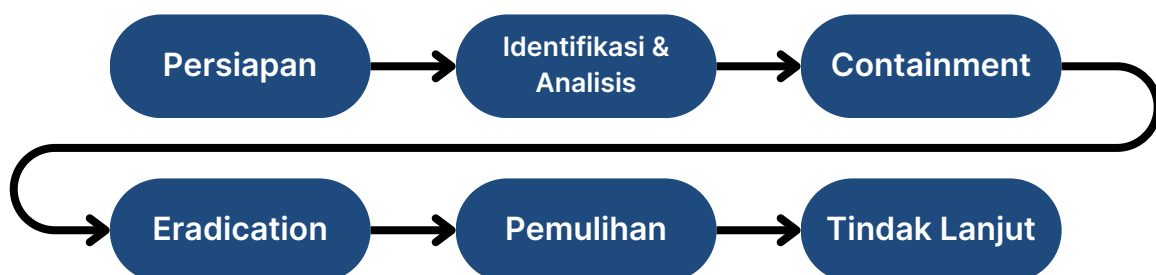
Panduan ini berisi langkah-langkah yang harus diambil apabila terjadi serangan SQL Injection, yang dimulai dari tahap persiapan sampai dengan tahap pembuatan laporan dari penanganan serangan. Panduan ini dapat dijadikan acuan bagi semua individu atau tim (administrator, pengelola TI, tim respon insiden keamanan komputer) yang bertanggung jawab untuk mencegah, mempersiapkan, atau menangani serangan SQL Injection pada suatu website.

PROSEDUR PENANGANAN SERANGAN SQL INJECTION

Penanganan serangan SQL Injection ditujukan untuk mencapai hal-hal sebagai berikut:

1. Mengumpulkan informasi sebanyak mungkin tentang serangan SQL Injection;
2. Menghalangi atau mencegah eskalasi kerusakan yang disebabkan oleh serangan tersebut;
3. Mengumpulkan bukti terkait serangan SQL Injection;
4. Mengambil langkah-langkah proaktif untuk mengurangi kemungkinan terjadinya serangan SQL Injection di masa depan.'

Supaya tujuan di atas dapat terlaksana dengan baik, maka penanganan terhadap serangan SQL Injection dilakukan dalam beberapa tahap sebagai berikut:



PERSIAPAN

Dalam melakukan penanganan serangan SQL Injection, perlu adanya tahap persiapan dengan prosedur sebagai berikut:

1. Pembentukan tim respon. Tim ini dapat berasal dari institusi yang mengalami serangan (internal) atau juga bisa berasal dari luar institusi (eksternal) apabila diperlukan. Anggota tim memiliki pengetahuan tentang SQL Injection dan memiliki kemampuan penanganannya;
2. Menyiapkan dokumen yang dibutuhkan dalam proses penanganan serangan SQL Injection. Dokumen ini antara lain meliputi:
 - a. Panduan penanganan insiden serangan siber;
 - b. Formulir penanganan insiden serangan siber;
 - c. Diagram yang menggambarkan hubungan antar komponen-komponen aplikasi yang membangun website (web server, aplikasi web, daftar user, network diagram).
3. Menyiapkan tools dan media yang dibutuhkan untuk penanganan. Misalnya Notepad++ untuk membaca log, IDS/IPS untuk memeriksa alert, SQL Map, Acunetix/Nessus untuk melakukan pengujian kembali atas kerentanan yang ditemukan.



IDENTIFIKASI DAN ANALISIS

Tujuan dari proses identifikasi dan analisis adalah:

1. Memahami sifat dan ruang lingkup kejadian;
2. Mengumpulkan informasi yang cukup tentang serangan SQL Injection sehingga tim respon dapat memprioritaskan langkah selanjutnya dalam menangani serangan tersebut, yang biasanya diikuti dengan penahanan sistem.

Pada tahap ini dilakukan proses identifikasi untuk memastikan telah terjadi serangan SQL Injection dan mendeteksi sumbernya. Langkah-langkah yang dapat diambil pada tahap identifikasi dan analisis antara lain:

1. Memeriksa alert dan anomali dari perangkat IDS atau IPS;
2. Melakukan error checking melalui form atau URL dengan memberikan karakter atau sebuah simbol. Misalnya:
 - a. Melalui form login, memasukan pada username dan password berupa karakter-karakter yang digunakan untuk SQL Injection, seperti:
 - OR 1=1 –
 - OR 1=2 --
 - OR 'a'='a'
 - b. Melalui URL, menambahkan karakter-karakter yang digunakan SQL Injection, seperti single quote, double quotes, atau double minus.
3. Memeriksa semua log (error log, access log, database log, hingga firewall log). Lokasi log file secara default berada pada var/log, log tersebut menyimpan seluruh aktivitas yang terjadi pada sistem;
4. Memeriksa adanya command line atau string-string yang digunakan untuk penyerangan;
5. Memeriksa isi database untuk mencari script yang berbahaya dan memeriksa apakah ada penambahan user secara tidak sah;
6. Memeriksa apakah ada file atau script berbahaya (trojan, malicious file, backdoor) yang ditanamkan pada web server;
7. Menggunakan tools untuk memeriksa kerentanan. Tool yang dapat digunakan diantaranya Acunetix, Nessus, SQLMap, atau SQL Injection tools lainnya.

Mengukur dampak dari terjadinya SQL Injection meliputi:

1. Terhadap kelangsungan proses bisnis, indikatornya adalah seberapa besar dari fungsi-fungsi bisnis yang terdapat pada website yang mengalami gangguan;
2. Terhadap sistem dan informasi, apakah penyerang melakukan distribusi malware, membuat backdoor atau melakukan web defacement. Selain itu, apakah ada data dan informasi yang berubah atau terhapus.

CONTAINMENT

Setelah dipastikan bahwa memang benar telah terjadi serangan SQL Injection, maka dilakukan proses berikutnya (containment) dengan tujuan:

1. Tidak terjadi kerusakan lebih dalam atau meluas;
2. Mencegah penyerang masuk lebih dalam ke sistem yang terkena dampak;
3. Melindungi server-server lain yang terhubung dengan aplikasi web.

Prosedur yang dilakukan pada tahap ini adalah:

1. Melakukan proses backup semua data yang terdapat pada web server. Backup sebaiknya ditempatkan pada hard disk eksternal. File pencadangan ini dapat juga digunakan untuk pengumpulan bukti-bukti dan keperluan forensik digital;
2. Jika sumber penyerangan berasal dari sistem lain pada jaringan, maka putuskan secara fisik koneksi tersebut dan lakukan investigasi sumber tersebut.

ERADICATION

Tahap Eradication pada penanganan serangan SQL Injection adalah untuk menghapus file/script serta menutup sumber serangan. Prosedur untuk melakukan proses ini dapat dilakukan dengan cara berikut:

1. Memeriksa apakah terdapat malicious file, backdoor, rootkit atau kode-kode berbahaya lainnya yang berhasil ditanamkan pada server dan segera menghapusnya;
2. Jika terdapat kode SQL yang mengakses IP tertentu maka perlu melakukan block/menutup sumber serangan (memblokir IP dan Port).

PEMULIHAN

Pemulihan merupakan tahap untuk mengembalikan seluruh sistem bekerja normal seperti semula. Prosedur yang dapat dilakukan sebagai berikut:

1. Mengubah kredensial password pengguna. Hal ini untuk mengantisipasi apabila password pengguna telah diketahui oleh penyerang;
2. Melakukan recovery database pada aplikasi web;
3. Jika SQL Injection menyebabkan web defacement, gunakan panduan penanganan insiden web defacement;
4. Jika SQL Injection menyebabkan insiden malware, gunakan panduan penanganan insiden malware;
5. Menutup semua kerentanan yang telah diketahui;
6. Membatasi akses root langsung ke database;
7. Melakukan filter terhadap input yang dimasukkan oleh pengguna;
8. Mematikan atau menyembunyikan pesan-pesan error yang keluar dari SQL Server yang berjalan;
9. Patching terhadap aplikasi yang rentan, melakukan upgrade terhadap aplikasi web yang masih memiliki kerentanan;
10. Melakukan penetration testing untuk mengetahui celah-celah keamanan yang mungkin masih terdapat pada website.



TINDAK LANJUT

Tahap ini adalah fase di mana semua dokumentasi kegiatan yang dilakukan dicatat sebagai referensi untuk digunakan di masa mendatang. Tujuan dari tahap ini adalah untuk:

1. Pelaporan, membuat laporan mengenai langkah-langkah dan hasil yang telah didapatkan pada penanganan serangan SQL Injection;
2. Mengambil pelajaran dan membuat rekomendasi untuk mencegah insiden terjadi lagi.

Prosedur yang dapat dilakukan adalah sebagai berikut:

1. Membuat dokumentasi dan laporan terkait penanganan serangan SQL Injection;
2. Menuliskan tools apa saja yang digunakan dalam penanganan serangan SQL Injection;
3. Menuliskan bukti-bukti yang ditemukan, hal ini terkait dengan proses hukum kedepannya;
4. Memberikan analisa dan penjelasan apa yang harus dilakukan sehingga serangan serupa tidak terulang kembali;
5. Membuat evaluasi dan rekomendasi.





govcsirt@bssn.go.id



@govcsirt_id



+62 851-2312-3940

Indonesian Government Computer Security Incident Response Team
Gov-CSIRT Indonesia

Badan Siber dan Sandi Negara